

Dual-EC DRBG

Introduction

En cryptographie, la génération de nombres aléatoires est essentielle. Chaque clé, chaque protocole de sécurité dépend de la qualité de cet aléa. Dual-EC DRBG, pour Dual Elliptic Curve Deterministic Random Bit Generator, est un générateur pseudo-aléatoire basé sur les courbes elliptiques. Il a été intégré aux standards du NIST avant d'être remis en cause.

Ce rapport vise à comprendre le fonctionnement de Dual-EC DRBG, ses bases mathématiques et la nature de la faille qui a conduit à son abandon. L'objectif est de comprendre comment un générateur présenté comme sûr a pu se révéler vulnérable, et ce que cela implique pour la confiance dans les outils cryptographiques alors qu'il est impératif de disposer de générateurs sûrs (CSPRNG).

Contexte

Développé au début des années 2000 avec l'implication de la NSA, DUAL_EC_DRBG a été proposé comme alternative basée sur la théorie des nombres aux générateurs existants (souvent basés sur des hachages ou des chiffrements symétriques). L'idée était qu'en confiant la sécurité du générateur à un problème mathématique difficile (le problème du logarithme discret sur une courbe elliptique), on pourrait obtenir des garanties théoriques de sécurité, voire une preuve de solidité.

Malgré le scepticisme initial de la communauté scientifique, DUAL_EC_DRBG a été adopté en 2006 par le NIST (National Institute of Standards and Technology) dans sa norme de référence SP 800-90A, aux côtés de trois autres algorithmes de génération aléatoire. Il a également été standardisé par l'ANSI et l'ISO, gagnant ainsi une portée internationale. Pendant sept ans, DUAL_EC_DRBG est resté l'un des générateurs approuvés, jusqu'à ce que de graves doutes sur sa sécurité ne conduisent finalement à son retrait officiel en 2014.

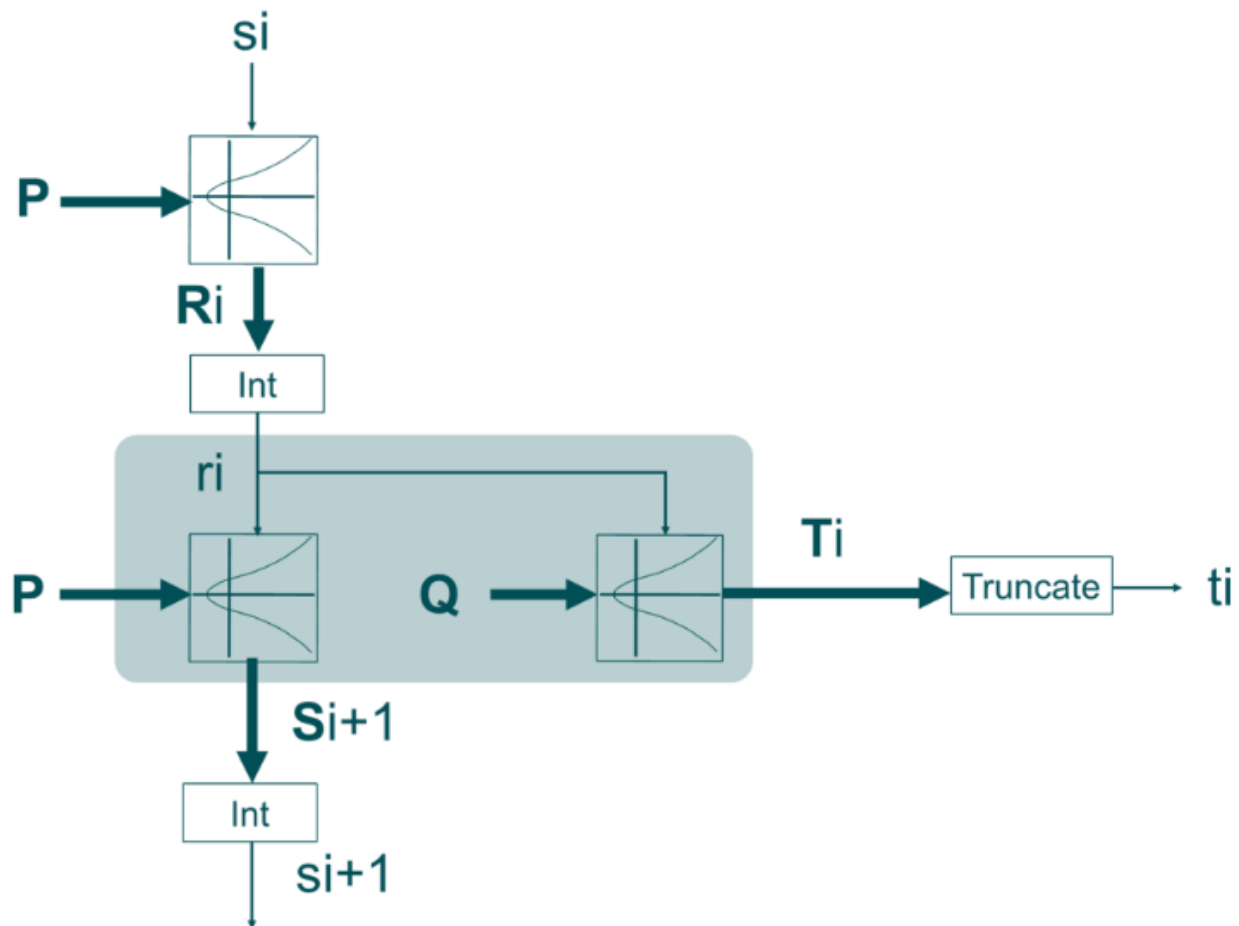
Il faut noter qu'avant même sa standardisation, des experts avaient relevé des faiblesses et émis des critiques. En 2006, par exemple, le cryptologue Kristian Gjøsteen montrait que certains aspects de DUAL_EC_DRBG n'étaient "pas cryptographiquement solides", identifiant un biais non négligeable dans la production de bits aléatoires. De plus, le générateur était extrêmement lent, environ cent fois plus lent que d'autres PRNG basés sur des fonctions de hachage, ce qui le rendait peu pratique dans de nombreux contextes. Malgré ces signaux d'alerte (absence de preuve de sécurité formelle, biais statistique, performances médiocres), le standard a été finalisé sans corrections notables sur ces points.

Dans la suite de ce rapport, nous allons expliquer le fonctionnement interne de DUAL_EC_DRBG, ses fondements mathématiques et l'hypothèse de sécurité qui était censée le protéger. Nous reviendrons ensuite sur la découverte de sa vulnérabilité majeure, suspectée d'être une porte dérobée intentionnelle, et sur le rôle controversé de la NSA dans cette affaire. Un exemple concret d'impact sera présenté à travers le cas de RSA BSAFE et le contrat liant RSA à la NSA. Enfin, nous proposerons une analyse critique des enseignements à tirer de l'affaire DUAL_EC_DRBG en matière de sécurité et de standardisation cryptographique, avant de conclure sur les leçons de cette histoire.

Principe de fonctionnement de DUAL_EC_DRBG

DUAL_EC_DRBG est un générateur déterministe de bits aléatoires reposant sur les courbes elliptiques. Son état interne est un entier (une valeur de 256 bits dans la configuration la plus courante) noté s . L'algorithme utilise deux points constants, notés P et Q , définis sur une courbe elliptique standard (par exemple la courbe NIST P-256). Ces points sont les paramètres publics du générateur et sont fournis par la norme.

Le fonctionnement peut être décrit simplement en deux phases à chaque itération: une phase de mise à jour de l'état interne et une phase de production de la sortie aléatoire. Figure 1 ci-dessous illustre ce processus.



Chaque tour prend l'état interne courant s_i et le met à jour via une multiplication par P . Le nouvel état s_{i+1} sert ensuite à calculer la sortie aléatoire en multipliant ce point Q et en extrayant l'abscisse du point résultant. Une troncature est appliquée pour ne conserver que 30 octets de sortie.

A partir d'un état interne initial (issu éventuellement d'une graine aléatoire de départ), le générateur effectue les opérations suivantes à chaque demande de nombres aléatoires:

1. Mise à jour de l'état interne : calcul d'un nouveau point en multipliant le point fixe P par la valeur numérique de l'état courant. On calcule le point P^{s_i} . On extrait ensuite l'abscisse x de ce point P^{s_i} . Cette abscisse devient la nouvelle valeur de l'état interne s_{i+1} .
2. Génération de la sortie aléatoire : à partir du nouvel état s_{i+1} , le générateur multiplie cette fois le point fixe Q par s_{i+1} . On obtient le point $Q^{s_{i+1}}$. L'abscisse, r pour "résultat" sera tronquée afin d'obtenir des bits aléatoires utilisables. Dans la spécification de NIST P-256, ne sont conservés que les 240 bits de poids faible (soit 30 octets) comme sortie aléatoire. Si davantage de bits sont requis, le générateur calculera autant de nouveaux états et de nouvelles sorties pour fournir le volume de données demandé.

Le point P fait évoluer de manière apparemment imprévisible, tandis que le point Q produit la sortie. La troncature de 16 bits, quant à elle, est censée éviter qu'un attaquant puisse remonter trop facilement de la sortie vers l'état interne exact, nous verrons plus loin que c'est précisément là que le bât blesse.

Il convient de noter que, bien que DUAL_EC_DRBG respecte ce schéma général, il propose aussi des fonctionnalités optionnelles comme l'additional input (apport de données supplémentaires pour re-mélanger l'état à chaque tour) ou des opérations de ré-initialisation périodique avec une nouvelle valeur aléatoire. Dans

la suite, nous nous concentrerons sur le fonctionnement de base sans additional input, car c'est dans ce mode que la faille de sécurité est la plus flagrante.

Fondement mathématique et hypothèse de sécurité

La sécurité revendiquée de DUAL_EC_DRBG repose sur la difficulté du problème du logarithme discret sur les courbes elliptiques.

Lorsque l'on a deux points P et $Q = d \cdot P$ sur une courbe elliptique (avec d un entier secret), il est facile de calculer Q à partir de P et d . En revanche, retrouver d en connaissant seulement P et Q est considéré comme un problème quasi-insoluble lorsque la courbe et les paramètres sont bien choisis.

Si les points P et Q sont choisis de manière aléatoire et indépendante, personne ne connaît de relation facile entre eux. Par conséquent, même en observant des sorties du générateur, un attaquant ne devrait pas être en mesure de remonter à l'état interne sans résoudre un problème de logarithme discret. Prédire le générateur reviendrait à casser la sécurité elliptique elle-même, ce qui est supposé hors de portée.

Un document de 2006 de Daniel R. L. Brown (chercheur chez Certicom) formulait d'ailleurs cette hypothèse en des termes très clairs :

"This proof makes essential use of Q being random. The reason for this is more than just to make the proof work. If Q is not random, then it may be the case the adversary knows a d such that $dQ = P$. Then $dR_i = dS_{i+1}$, so that such a distinguisher could immediately recover the secret prestates from the output. Once the distinguisher gets the prestates, it can easily distinguish the output from random. Therefore, it is generally preferable for Q to be chosen randomly, relative to P ."

La condition de sécurité fondamentale est que personne ne puisse connaître de facteur reliant P et Q . Si cette condition est remplie, alors le meilleur moyen de deviner les sorties de DUAL_EC_DRBG serait de résoudre un logarithme discret.

Il est important de souligner que l'attrait de DUAL_EC_DRBG résidait dans cette promesse de sécurité "réductionniste" basée sur un problème dur. Contrairement à d'autres PRNG dont la robustesse se fonde sur des considérations plus empiriques ou sur la difficulté à inverser des fonctions de hachage (ce qui n'est pas une garantie mathématiquement prouvée), on espérait pouvoir apporter une preuve de sécurité pour DUAL_EC_DRBG.

Toutefois, aucune preuve n'a jamais été publiée par ses auteurs. Au contraire, des chercheurs ont rapidement trouvé des faiblesses : nous avons mentionné le biais statistique découvert en 2006, mais surtout, il a été démontré que le générateur révélait beaucoup trop de bits de son état interne à chaque tour. En effet, sur 256 bits d'état, 240 bits sont divulgués dans la sortie ce qui signifie que l'essentiel de l'information secrète fuit à chaque nombre produit. En comparaison, d'autres générateurs ne fournissent qu'une fraction plus limitée de leur état pour éviter toute attaque par retour en arrière.

Sur le papier, DUAL_EC_DRBG est censé être sûr si les constantes P et Q sont choisies de manière transparente et intègre. Mais l'absence d'indication sur la façon dont P et Q ont été générés dans la norme NIST, conjuguée à la grande quantité de bits révélés, ouvrait déjà la porte à des soupçons. Malheureusement, ces soupçons se sont avérés fondés : la sécurité théorique de DUAL_EC_DRBG a été mise en échec par une vulnérabilité

intentionnelle, comme nous allons le voir.

----- Original Message -----
Subject: RE: Minding our Ps and Qs in Dual_EC
From: "Don Johnson" <DJohnson@cygnacom.com>
Date: Wed, October 27, 2004 11:42 am
To: "John Kelsey" <john.kelsey@nist.gov>

John,

P = G.
Q is (in essence) the public key for some random private key.

It could also be generated like a(nother) canonical G, but NSA kyboshed this idea, and I was not allowed to publicly discuss it, just in case you may think of going there.

Don B. Johnson

Découverte de la vulnérabilité et soupçon de porte dérobée

Dès 2007, seulement un an après la publication officielle de DUAL_EC_DRBG, deux chercheurs de Microsoft, Dan Shumow et Niels Ferguson, ont présenté lors d'une conférence (Crypto 2007, en session informelle "rump session") des résultats troublants suggérant la présence possible d'une backdoor (porte dérobée) dans l'algorithme. Ils ont démontré qu'un attaquant capable de connaître la relation secrète entre P et Q (le d de $Q = d \cdot P$) pourrait, en observant un faible volume de sortie du générateur, récupérer l'état interne du PRNG et ainsi prédire toutes ses sorties futures. Leur présentation, intitulée de manière éloquente "On the possibility of a Back Door in the NIST Dual EC PRNG", n'accusait personne explicitement, mais pointait du doigt les "constantes mystérieuses" présentes dans la norme. En effet, ni P ni Q n'étaient accompagnés d'une explication quant à leur origine, contrairement à la pratique recommandée (par exemple, on génère souvent des constantes à partir de nombres bien connus comme π pour prouver qu'on n'a pas choisi une valeur intentionnellement piégée). Shumow et Ferguson ont montré que ces constantes pouvaient être interprétées comme une clé publique d'un mécanisme de trappe : si quelqu'un détenait la clé privée correspondante, cette personne pourrait prédire le générateur.

À l'époque, l'exposé de Shumow et Ferguson a surpris, mais l'impact est resté modéré. Quelques experts de renom, ont très vite tiré la sonnette d'alarme. Le cryptologue Bruce Schneier, a publié dès novembre 2007 un billet de blog déconseillant fermement d'utiliser DUAL_EC_DRBG "en aucune circonstance". Schneier évoquait explicitement la possibilité d'une porte dérobée de la NSA dans le générateur. En écho, plusieurs entreprises et projets open-source ont commencé à éviter d'implémenter DUAL_EC_DRBG. Par exemple, la bibliothèque OpenSSL l'incluait uniquement pour des raisons de certification FIPS mais sans l'activer par défaut, si bien qu'un bug a même fait que son implémentation ne fonctionnait pas du tout, passant inaperçue pendant des années.

La véritable confirmation est arrivée en 2013, grâce aux révélations retentissantes d'Edward Snowden sur les programmes de surveillance de la NSA. En septembre 2013, le New York Times et le Guardian ont rapporté que la NSA avait activement œuvré pendant le processus de standardisation pour orienter le choix des constantes de Dual_EC_DRBG, dans le cadre d'un programme secret de la NSA (nom de code BULLRUN) visant à affaiblir les outils de chiffrement. D'après ces documents classifiés (jamais publiés in extenso, mais résumés par les journalistes), la backdoor était bien réelle et délibérément introduite par la NSA. Autrement dit, la NSA aurait choisi les points P et Q de telle sorte qu'elle connaisse la fameuse relation secrète (la valeur d). Dès lors, Dual_EC_DRBG n'était plus qu'un cheval de Troie mathématique : l'agence disposait d'un avantage lui permettant de prédire les nombres aléatoires générés et, par extension, de casser les communications chiffrées s'appuyant sur ces nombres.

En parallèle, une enquête de l'agence de presse Reuters a révélé un fait tout aussi troublant : RSA Security, une entreprise majeure du secteur, aurait touché 10 millions de dollars de la part de la NSA pour intégrer DUAL_EC_DRBG comme générateur par défaut dans son produit phare de l'époque, la librairie de cryptographie RSA BSAFE. Mentionnons d'ores et déjà que RSA a nié avoir sciemment affaibli la sécurité de ses produits, tout en reconnaissant avoir entretenu un partenariat étroit avec la NSA.

Comment fonctionne concrètement la faille/backdoor ?

Imaginons qu'un attaquant observe la sortie de 30 octets issue d'un Dual_EC_DRBG ciblé (par exemple, les 30 octets aléatoires envoyés en clair lors d'une poignée de main TLS). Appelons cette valeur observée $R_{\text{tronqué}}$ (puisque'elle a été tronquée de 16 bits). L'attaquant procède alors ainsi :

1. Recherche d'un R complet : Une recherche par brute force des 65 536 possibilités (2^{16}), et la vérification de celles qui se trouvent sur la courbe elliptique (chaque valeur d'abscisse peut donner 0, 1 ou 2 points possibles).
2. Exploitation de la relation d (backdoor) : $R = Q^{s_{i+1}} = d \cdot (P^{s_{i+1}})$, l'attaquant peut calculer $T = d^{-1} \cdot R$ (l'ordre de la courbe).
Or $T = d^{-1} \cdot (d \cdot (P^{s_{i+1}})) = P^{s_{i+1}}$. Ainsi, en appliquant d^{-1} à un candidat R , l'attaquant obtient un point T censé correspondre à $P^{s_{i+1}}$, c'est-à-dire au point utilisé pour mettre à jour l'état à la génération précédente. Avec l'abscisse de T , l'attaquant obtient une valeur candidate pour l'état interne s_{i+2} , l'état interne du générateur à la fin de l'itération observée.
3. Vérification et prédiction : En connaissant maintenant P et Q, l'attaquant peut simuler le générateur Dual_EC_DRBG sur l'étape suivante et la comparer à la valeur véritable observée. Deux itérations successives lèvent toute ambiguïté. L'attaquant peut désormais tout recalculer et donc tout déchiffrer ou usurper.

Ce scénario était celui redouté par les chercheurs et qui a conduit à la crise Dual_EC_DRBG. Soulignons que le NIST a tenté en 2007 de répondre (en partie) à la menace en publiant une révision de SP 800-90A qui ajoutait une étape de mélange additionnel pour renforcer la résistance à l'extraction de l'état (backtracking resistance). Mais cette modification s'est avérée insuffisante : comme le note le rapport de M. Green et al., l'ajout de données externes (additional input) peut contrarier l'attaque si ces données restent inconnues de l'adversaire, mais le mécanisme de base de la porte dérobée demeure exploitable dans de nombreux cas pratiques (beaucoup d'implémentations n'utilisaient pas de additional input systématique, ou bien celui-ci pouvait être deviné s'il provenait d'une source faiblement aléatoire).

Enfin, il convient de mentionner une évolution inquiétante de cette histoire : en 2015, l'entreprise Juniper Networks a découvert qu'une variante de la porte dérobée Dual_EC_DRBG avait été insérée furtivement dans le firmware de certains de ses produits de sécurité (firewalls ScreenOS), très probablement par un acteur malveillant externe. Concrètement, Juniper utilisait Dual_EC_DRBG (imposé possiblement à l'origine pour des raisons réglementaires), et un attaquant inconnu avait modifié la constante Q dans le code source, substituant un Q différent sans que personne ne s'en aperçoive pendant un temps. Cette modification clandestine a effectivement introduit une porte dérobée permettant de déchiffrer le trafic VPN passant par ces firewalls, illustrant le risque que d'autres acteurs que la NSA réutilisent ce genre de vulnérabilité à leurs propres fins. Cet épisode a jeté un nouvel éclairage sur Dual_EC_DRBG : non seulement la NSA a pu l'utiliser, mais la présence même de cette faiblesse a ouvert la voie à un abus par des tiers, ce qui est peut-être le pire scénario possible pour une porte dérobée gouvernementale mal contrôlée.

Étude de cas : RSA BSAFE, contrat avec la NSA et impact sur la confiance

L'affaire DUAL_EC_DRBG a connu un retentissement particulier lorsqu'il est apparu que l'entreprise RSA Security (maintenant une division d'EMC) avait, en quelque sorte, servi de vecteur de diffusion pour le générateur compromis. RSA est notamment connue pour sa bibliothèque de fonctions cryptographiques BSAFE, très utilisée historiquement pour implémenter le chiffrement dans divers logiciels commerciaux. Or, à partir de 2004, RSA BSAFE a intégré DUAL_EC_DRBG et l'a même défini comme générateur aléatoire par défaut dans ses toolkits de chiffrement.

En 2013, Reuters a dévoilé qu'un accord financier secret de 10 millions de dollars avait été conclu entre la NSA et RSA en 2004 pour encourager cette décision. Si la somme peut paraître modeste à l'échelle d'une agence gouvernementale, il faut se rappeler qu'elle représentait à l'époque plus d'un tiers du chiffre d'affaires annuel de la division Sécurité de RSA – un incitatif non négligeable. En échange, RSA aurait donc choisi d'utiliser Dual_EC_DRBG dans BSAFE, contribuant à le propager chez de nombreux clients (éditeurs de logiciels, industriels, etc.) qui se fiaient à RSA pour des choix cryptographiques sûrs.

L'affaire fut un véritable scandale dans le milieu de la cybersécurité. RSA a publié un démenti catégorique, niant avoir "conclu un contrat secret pour affaiblir délibérément [ses] produits". La société s'est défendue en expliquant que, vers 2004, les algorithmes à base de courbes elliptiques étaient en vogue et considérés comme l'avenir de la cryptographie, et que dans ce contexte elle avait intégré Dual_EC_DRBG de bonne foi, pensant offrir le "meilleur niveau de sécurité" à ses clients. RSA a souligné que Dual_EC_DRBG n'était qu'une option parmi d'autres dans BSAFE (plusieurs PRNG étaient disponibles, dont des PRNGs basés sur SHA-1, etc.), et que les clients restaient libres d'en choisir un autre. Elle a aussi justifié le maintien de Dual_EC_DRBG dans ses offres même après 2007 en arguant qu'elle suivait les recommandations du NIST tant que celui-ci n'avait pas officiellement déclassé l'algorithme.

Ces explications n'ont pas entièrement convaincu la communauté. Beaucoup ont reproché à RSA un grave manquement éthique ou pour le moins un manque de jugement : soit l'entreprise a sciemment vendu la confiance de ses clients (hypothèse du cynisme intéressé), soit elle a fait preuve de négligence en ne réagissant pas dès 2007 aux alertes publiques sur Dual_EC_DRBG (hypothèse de l'erreur de jugement). Dans les deux cas, l'image de RSA a été sévèrement écornée. Plusieurs experts de renommée ont publiquement boycotté la conférence RSA Conference 2014 en signe de protestation, refusant d'être associés à une entreprise ayant potentiellement collaboré à affaiblir la sécurité pour ses clients. L'incident a ravivé les souvenirs d'événements antérieurs (comme la découverte dans les années 1990 que la NSA avait influencé l'algorithme Clipper Chip), en bien plus grave : ici, c'est un standard international qui était en cause, et la confiance dans l'ensemble du processus de standardisation cryptographique s'en est trouvée ébranlée.

Le cas RSA BSAFE illustre aussi un paradoxe malheureux : de nombreux utilisateurs finaux n'ont jamais explicitement choisi Dual_EC_DRBG, mais il a pu se retrouver dans leurs systèmes par défaut via des bibliothèques tierces de confiance. Par exemple, des produits comme les pare-feu McAfee, des logiciels d'authentification, etc., incorporaient BSAFE et ont donc embarqué Dual_EC_DRBG sans que leurs développeurs ou clients en soient conscients. Ce n'est qu'après la directive du NIST en 2013 déconseillant fortement Dual_EC_DRBG que RSA a publié des correctifs changeant le défaut de BSAFE et a communiqué vers ses clients pour qu'ils évitent désormais cet algorithme. Malheureusement, pendant plusieurs années, un grand nombre d'applications ont pu utiliser un générateur possédant une faille critique, sapant potentiellement la sécurité de données sensibles, le tout au nom d'une confiance mal placée.

L'affaire RSA/NSA a accentué la crise de confiance envers les institutions : confiance envers les fournisseurs de solutions de sécurité (on attend d'eux qu'ils soient vigilants et transparents, pas qu'ils servent de relais à des agences de renseignement), et confiance envers les organismes de standardisation comme le NIST. Ce dernier a dû publier un communiqué en 2013 rappelant qu'il n'affaiblirait jamais volontairement un standard, et a entrepris de réviser ses processus d'élaboration des standards pour y inclure davantage de commentaires publics et de diversité dans les comités. Le NIST a notamment retiré officiellement Dual_EC_DRBG de sa liste

de générateurs approuvés en 2014, tournant ainsi la page de ce qui restera comme l'un des plus grands fiascos cryptographiques.

Enseignements

L'affaire DUAL_EC_DRBG nous offre de précieux enseignements sur la sécurité des systèmes cryptographiques et sur la confiance que l'on peut accorder aux standards.

Transparence et ouverture des standards

L'un des problèmes flagrants de Dual_EC_DRBG a été le manque de transparence dans le choix de ses constantes. Les valeurs P et Q ont été fournies sans explication ni méthode de génération vérifiable. À l'avenir, il est indispensable que les standards cryptographiques respectent scrupuleusement le principe du "nothing up my sleeve" : toute constante arbitraire doit être justifiée ou générée de façon publique (par exemple à partir de chiffres universellement reconnus). De plus, les processus de standardisation doivent être ouverts à la communauté : bien des signaux d'alarme ont été ignorés ou écartés. Une revue par les pairs plus large et plus de poids accordé aux critiques auraient pu empêcher la propagation d'un algorithme aussi contesté.

Indépendance des organismes de standardisation

L'implication de la NSA dans les travaux de l'ANSI, de l'ISO et du NIST est à double tranchant. D'un côté, la NSA emploie d'excellents cryptographes et a contribué positivement par le passé (par exemple en renforçant DES face à la cryptanalyse différentielle dès les années 1970). Mais de l'autre, la mission de la NSA comporte une composante offensive (le renseignement) qui peut entrer en conflit d'intérêt avec la mission de sécurité publique des standards. Le cas Dual_EC_DRBG a montré que la NSA n'a pas hésité à promouvoir un standard qu'elle savait vulnérable, dans l'espoir de l'exploiter. Cela invite à mieux cloisonner l'élaboration des standards des influences d'agences ayant des intérêts propres. Une proposition d'amélioration pourrait être d'internationaliser davantage les comités, d'y inclure des experts académiques indépendants, et de rendre publics les débats techniques pour réduire le risque de manipulation en coulisses.

Importance d'une diversité d'algorithmes:

Un autre enseignement est qu'il faut éviter de mettre tous ses œufs dans le même panier. Dans SP 800-90A, heureusement, il y avait trois autres PRNG (basés sur SHA-1, SHA-256 et AES) qui n'étaient pas soupçonnés de backdoor. De nombreux produits ont pu basculer sur ces alternatives dès que Dual_EC_DRBG a été mis en cause. Cela souligne la nécessité pour les implémenteurs d'offrir plusieurs choix algorithmiques et d'être prêts à en déconseiller/déprécier un si des failles sont découvertes. La capacité à changer rapidement de primitive est vitale. De plus, cela doit s'accompagner d'une veille active : dans le cas RSA, on peut reprocher qu'entre 2007 et 2013, l'entreprise n'ait pas retiré Dual_EC_DRBG de son défaut, malgré les mises en garde. La réactivité face aux évolutions de la recherche en sécurité est un impératif professionnel.

Renforcement des exigences de preuve et d'audit

La communauté a appelé à des exigences accrues lors de l'introduction de nouveaux algorithmes cryptographiques. Un algorithme qui se présente comme "plus sûr" doit être accompagné d'au moins un argument de sécurité formel (par exemple, une réduction prouvant que casser l'algorithme implique de résoudre tel problème réputé difficile). Or, Dual_EC_DRBG n'avait aucune preuve, et même des analyses indiquant l'inverse (biais détecté, absence de réduction, etc.). À l'avenir, on attend des standards qu'ils s'appuient sur des bases solides, ou qu'à minima leur code source/implémentation soient audités de façon indépendante. L'essor des logiciels libres et de la cryptographie open-source va dans ce sens : il est plus difficile de cacher une trappe dans un code ouvert analysé par la communauté.

Synthèse

L'affaire DUAL_EC_DRBG a renforcé la vigilance de toute une industrie. Elle a également eu pour effet bénéfique de sensibiliser le grand public aux questions de confiance dans la cryptographie (beaucoup de médias généralistes ont couvert l'histoire en liant le sujet aux révélations Snowden). Aujourd'hui, développeurs et utilisateurs sont plus enclins à questionner l'origine des composants de sécurité qu'ils utilisent.

Conclusion

DUAL_EC_DRBG restera sans doute dans les annales de la cryptographie comme un exemple emblématique de ce qu'il ne faut pas faire – et de ce qui peut arriver lorsque la confiance est trahie. Conçu sous l'influence d'une agence de renseignement, standardisé malgré des signaux d'alarme, puis démonté par la communauté et finalement confirmé comme vecteur de surveillance, ce générateur pseudo-aléatoire a ébranlé nombre de certitudes.

La première leçon à tirer est que la confiance aveugle n'a pas sa place en cryptographie. Chaque algorithme, chaque constante, chaque ligne de code mérite d'être examinée, questionnée, et son origine clarifiée. La cryptographie moderne s'est bâtie sur la transparence (principe de Kerckhoffs où seule la clé est secrète, pas l'algorithme) et la collaboration ouverte entre chercheurs. L'affaire Dual_EC_DRBG vient rappeler que lorsque ces principes ne sont pas respectés, les conséquences peuvent être graves.

La deuxième leçon concerne l'équilibre entre sécurité et surveillance. Introduire volontairement une faiblesse dans un standard destiné à protéger les communications globales s'est révélé être une arme à double tranchant. Même si l'intention était de réserver l'accès à la NSA, en pratique cela a mis en danger tout un écosystème et sapé la crédibilité des institutions américaines dans le domaine de la cryptographie. Cela conforte la position de nombreux experts selon laquelle nous devons renforcer les systèmes sans aucune ambiguïté, car affaiblir la cryptographie pour un acteur, c'est l'affaiblir pour tous.

Enfin, on peut voir dans la découverte de la faille Dual_EC_DRBG et la réaction de la communauté un signe de résilience du monde de la cybersécurité. Des chercheurs indépendants ont su détecter et exposer le problème, des voix respectées ont su alerter le public, et in fine des mesures ont été prises (retrait du standard, correctifs logiciels, etc.). Les erreurs du passé servent désormais d'avertissement pour les générations futures de concepteurs de standards : l'exigence de probité et de qualité en cryptographie est intransigeante.

En conclusion, l'histoire de DUAL_EC_DRBG aura été un catalyseur pour améliorer la transparence et la robustesse des normes de sécurité. Il appartient à la communauté (experts, organismes de normalisation, industriels et même utilisateurs informés) de rester vigilante pour que de tels épisodes ne se reproduisent plus. La confiance est longue à bâtir et facile à détruire : à nous de la préserver en gardant la cryptographie aussi solide et honnête que possible.

Bibliographie

- [Wikipédia: DUAL_EC_DRBG](#)
- [Entrust: Zero to Dual_EC_DRBG in 30 minutes](#)
- [NIST: 800-90 and Dual EC DRBG](#)
- [Cloudflare: How the NSA \(may have\) put a backdoor in RSA's cryptography: A technical primer](#)
- [Youtube: Dual EC or the NSA's Backdoor: Explanations](#)
- [Gaspar Émilien: "Surveillance généralisée : Dual_EC_DRBG, 10 ans après"](#)
- [Kim Zetter: "How a Crypto 'Backdoor' Pitted the Tech World Against the NSA"](#)